

Cyber Threat Intelligence

Executive Briefing

Report Date: July 11, 2026

Generated: 2026-07-11 14:43 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
7	5	2	0	20

2. Executive Summary

As of July 11, 2026, the security operations center has concluded an analysis of 20 identified vulnerabilities, categorized as 7 Critical, 5 High, 2 Medium, and 0 Low. This assessment indicates a high-risk security posture, characterized by vulnerabilities that, if exploited, provide unauthorized remote code execution capabilities. The primary priority is CVE-2026-54159, a PHP Object Injection vulnerability in the PrestaShop faceted search module, which warrants immediate attention due to its potential for total system compromise via the application layer. The organizational posture is currently elevated, requiring a shift to an emergency patching cycle to remediate critical exposures. Defensive teams must prioritize the deployment of vendor-supplied patches and implement compensatory controls to neutralize identified attack vectors within the next 24 to 48 hours.

3. Critical Action List

- Immediately remediate CVE-2026-54159 within 24 hours to prevent unauthorized PHP object injection.
- Implement vendor-supplied security patches for CVE-2026-50551 across all SiYuan instances within 24 hours.
- Remediate CVE-2026-54158 regarding XSS-to-RCE within 24 hours to mitigate potential code execution.
- Execute urgent remediation for CVE-2026-54067 within 24 hours to address critical XSS-to-RCE exposure.
- Apply emergency patches for remaining Critical-rated vulnerabilities within 48 hours.
- Initiate enterprise-wide patch deployment for all High-severity vulnerabilities within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-54159	PHP Object Injection in PrestaSho...	10.0	Critical	90/100	CWE-74
CVE-2026-50551	Stored Cross Site Scripting to RC...	9.9	Critical	89/100	CWE-79

CVE-2026-54158	Stored XSS to Remote Code Executi...	9.9	Critical	89/100	CWE-79
CVE-2026-54067	Stored XSS to Remote Code Executi...	9.9	Critical	89/100	CWE-79
CVE-2026-54088	Pre-Authentication Command Inject...	9.8	Unknown	88/100	CWE-78
CVE-2026-54069	Unauthenticated Administrative AP...	9.8	Unknown	88/100	CWE-346
CVE-2026-54072	Open Redirect Token Leakage in Au...	9.3	Critical	84/100	CWE-601
CVE-2026-54089	Authentication Bypass via Header ...	9.1	Critical	82/100	CWE-287
CVE-2026-54174	Package Integrity Verification By...	8.3	High	75/100	CWE-345
CVE-2026-53639	Insecure Direct Object Reference ...	9.1	Critical	73/100	CWE-639
CVE-2026-54071	Pickle Deserialization Code Execu...	7.8	High	70/100	CWE-502
CVE-2026-54063	Denial of Service via Unbounded R...	7.5	High	68/100	CWE-770
CVE-2026-54066	Arbitrary File Read via Path Trav...	7.5	High	68/100	CWE-22
CVE-2026-54651	Denial of Service via Infinite Lo...	5.5	Unknown	68/100	CWE-835
CVE-2026-54070	Stored XSS in SiYuan Bazaar Marke...	7.1	High	64/100	CWE-79
CVE-2026-54171	Sensitive Information Leakage via...	6.5	Medium	59/100	N/A
CVE-2026-54136	Authorization Bypass via API Path...	7.5	Unknown	59/100	CWE-863
CVE-2026-54068	SQLite Data Exfiltration via Temp...	5.9	Medium	53/100	CWE-306
CVE-2026-48861	CRLF Injection via Unvalidated Re...	7.2	Unknown	48/100	CWE-93
CVE-2026-54163	Content Security Policy Injection...	4.7	Unknown	42/100	CWE-79

5. Detailed Vulnerability Findings

CVE-2026-54159

Finding: PHP Object Injection in PrestaShop Faceted Search

CVSS v3.1 Score: 10.0 | Severity: Critical | Urgency Score: 90/100 | CWE: CWE-74

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The PrestaShop ps_facetedsearch module contains a PHP Object Injection vulnerability in its faceted search cache management subsystem. The root cause is the unsafe deserialization of untrusted cached search strings without proper validation of the serialized payload's classes. An unauthenticated remote attacker can exploit this vulnerability to trigger remote code execution by delivering a malicious serialized object, compromising the entire web server.

Proof of Concept (PoC):

An unauthenticated remote attacker targets a public-facing PrestaShop site running the ps_facetedsearch module. The attacker sends a crafted HTTP request containing a serialized PHP gadget chain within the URL parameters associated with the search cache. The application retrieves the malicious string and processes it using the PHP unserialize function within the cache handling logic. This results in the instantiation of arbitrary classes and subsequent execution of malicious operating system commands under the permissions of the web server.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54159>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54159>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54159>

CVE-2026-50551

Finding: Stored Cross Site Scripting to RCE in SiYuan

CVSS v3.1 Score: 9.9 | Severity: Critical | Urgency Score: 89/100 | CWE: CWE-79

Score Provenance: Unverified
MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

SiYuan is vulnerable to a stored cross-site scripting (XSS) vulnerability that escalates to remote code execution (RCE) via the attribute view asset cell component. The root cause is a lack of sanitization of input within cell content rendering processes, allowing HTML and JavaScript payloads to execute within the context of privileged desktop application APIs. An authenticated remote attacker with low privileges can exploit this to achieve complete remote code execution on the server or client hosting the SiYuan application.

Proof of Concept (PoC):

An authenticated remote user with low privileges logs into the SiYuan notebook system. The attacker creates a new attribute view and inserts a malicious <script> block containing privileged Node.js commands into the asset cell content. The server renders the attribute view, triggering the execution of the unsanitized script when the payload is loaded in the DOM. This results in the execution of arbitrary operating system commands on the host machine, leading to complete compromise.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50551>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50551>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50551>

CVE-2026-54158

Finding: Stored XSS to Remote Code Execution in SiYuan

CVSS v3.1 Score: 9.9 | Severity: Critical | Urgency Score: 89/100 | CWE: CWE-79

Score Provenance: Unverified
MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

SiYuan contains a stored cross-site scripting vulnerability in the `genAVValueHTML()` function of the attribute-view cell rendering component. The root cause is the omission of HTML sanitization when processing data fields parsed by the `genAVValueHTML()` renderer before rendering it in the application's view. An authenticated remote attacker with low privileges can exploit this to execute arbitrary code with systemic privileges on the victim's host device.

Proof of Concept (PoC):

An authenticated remote attacker with low-privilege access gains access to the target SiYuan instance. The attacker updates an attribute value with a crafted payload containing active HTML script blocks destined for processing by the `genAVValueHTML()` method. The application processes this update and outputs the unsanitized script directly to the user interface during cell rendering. This results in the execution of arbitrary JavaScript commands in a context with desktop-level API permissions, allowing complete command execution.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54158>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54158>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54158>

CVE-2026-54067

Finding: Stored XSS to Remote Code Execution in SiYuan

CVSS v3.1 Score: 9.9 | Severity: Critical | Urgency Score: 89/100 | CWE: CWE-79

Score Provenance: Unverified
MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

SiYuan is vulnerable to a stored cross-site scripting vulnerability that escalates to remote code execution in its `renderSnippet()` function. The root cause is a lack of character escaping inside the CSS snippet parser, allowing an attacker to break out of `<style>` HTML tags. An authenticated remote attacker with low-level privileges can exploit this to inject malicious scripts, achieving arbitrary system execution on the host machine.

Proof of Concept (PoC):

An authenticated remote user with low privileges logs into a SiYuan instance. The attacker uploads a custom CSS snippet containing HTML closing style tags and an active script payload targeting the `renderSnippet()` function. The application processes and renders the snippet template without escaping the closing tags, causing the browser to execute the script in a highly privileged sandbox. This results in remote code execution on the server or the client's local environment through the application's native system execution features.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54067>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54067>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54067>

CVE-2026-54088

Finding: Pre-Authentication Command Injection in File Browser

CVSS v3.1 Score: 9.8 | Severity: Unknown | Urgency Score: 88/100 | CWE: CWE-78

Score Provenance: Unverified
MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

File Browser suffers from a critical command injection vulnerability in its authentication hook configuration component. The root cause is the incorrect handling of shell substitution when executing user authentication hooks, permitting external variables to influence the command shell. An unauthenticated remote attacker can exploit this by sending a crafted authentication request to execute arbitrary commands, leading to complete host takeover.

Proof of Concept (PoC):

An unauthenticated remote attacker targets the exposed login portal of a File Browser instance. The attacker submits a POST login request to the authentication endpoint, injecting shell metacharacters such as backticks into the username field. The application passes this unvetted username parameter directly into the shell template string mapped to the custom authentication hook. This results in the execution of the injected shell commands at the system level before authentication occurs.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54088>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54088>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54088>

CVE-2026-54069

Finding: Unauthenticated Administrative API Access in SiYuan

CVSS v3.1 Score: 9.8 | Severity: Unknown | Urgency Score: 88/100 | CWE: CWE-346

Score Provenance: Unverified
MITRE ATT&CK: T1566, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

SiYuan contains an authentication bypass vulnerability in its CORS policy configuration that allows unauthenticated

access to administrative API endpoints. The root cause is a blanket allowlist policy for any chrome-extension:// origin, failing to restrict requests to trusted extension IDs. An unauthenticated remote attacker can leverage a malicious browser extension to execute arbitrary administrative commands against the local SiYuan application.

Proof of Concept (PoC):

An unauthenticated attacker induces a target user to install a malicious browser extension. The malicious extension sends an XMLHttpRequest to the local SiYuan administrative API port with the origin header set to its own chrome-extension:// URL. The local SiYuan server accepts the request and executes the administrative actions because of the over-permissive wildcard CORS configuration. This results in complete administrative control of the SiYuan application, including the ability to write and read arbitrary files.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54069>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54069>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54069>

CVE-2026-54072

Finding: Open Redirect Token Leakage in Authorizer

CVSS v3.1 Score: 9.3 | Severity: Critical | Urgency Score: 84/100 | CWE: CWE-601

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1566, T1071

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

Authorizer contains an open redirect vulnerability in its /authorize API endpoint. The root cause is a failure to validate the redirect_uri parameter against a whitelist of registered callback URLs before issuing redirects. An unauthenticated remote attacker can exploit this to leak sensitive OAuth2 access tokens and authorization codes to an attacker-controlled external domain.

Proof of Concept (PoC):

An unauthenticated remote attacker constructs a malicious link targeting the /authorize endpoint of the Authorizer instance. The attacker populates the redirect_uri parameter with a URL pointing to an attacker-controlled server instead of a valid application callback. A logged-in victim clicks the link, authorizing the request, which causes the Authorizer server to redirect the browser to the malicious URL with the user's session token appended to the hash. This results in the complete compromise of the victim's OAuth2 session as the token is recorded by the attacker's server.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54072>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54072>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54072>

CVE-2026-54089

Finding: Authentication Bypass via Header Forgery in File Browser

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-287

Score Provenance: Unverified

MITRE ATT&CK: T1556, T1621

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

File Browser is vulnerable to an authentication bypass vulnerability within its reverse proxy authentication handling module. The root cause is the failure of the application to verify if incoming proxy authentication headers originated from a trusted reverse proxy server. An unauthenticated remote attacker can exploit this by spoofing specific HTTP headers, gaining full administrative access to the File Browser instance.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies a File Browser instance configured to trust reverse proxy headers. The attacker sends a direct HTTP request to the target server, manually injecting the X-Forwarded-User proxy authentication header set to the target administrator's username. The application processes the request, reading the forged header values without checking if the request came from a whitelisted proxy IP. This results in the attacker bypassing all login screens and successfully logging in as the administrator.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54089>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54089>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54089>

CVE-2026-54174

Finding: Package Integrity Verification Bypass in Melange

CVSS v3.1 Score: 8.3 | Severity: High | Urgency Score: 75/100 | CWE: CWE-345

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1553, T1195

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	High

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

Melange contains a vulnerability in its package signature verification process where incomplete validation allows data section substitution. The root cause is a failure to cryptographically bind the payload metadata directly to the signed package segments during verification. A remote attacker could exploit this by substituting malicious data sections into signed packages, compromising the integrity of downstream system deployments.

Proof of Concept (PoC):

An unauthenticated remote attacker targets a system utilizing the Melange toolchain for package processing. The attacker crafts a modified package by replacing the data section while keeping the original valid signature intact. The package processor processes this malformed package and completes the verification phase successfully because it fails

to validate that all package sections are bound to the cryptographic signature. This results in the execution or installation of untrusted, attacker-controlled code within the victim's execution environment.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54174>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54174>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54174>

CVE-2026-53639

Finding: Insecure Direct Object Reference in Sylius Shop Payment API

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 73/100 | CWE: CWE-639

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1190, T1020

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	None

Description:

Sylius is vulnerable to an Insecure Direct Object Reference (IDOR) vulnerability on its Shop Payment Request API endpoints. The root cause is the absence of access control verification checks to ensure that the requesting session owns the referenced payment request resource. An unauthenticated remote attacker can exploit this to view or alter the payment details of other customers, resulting in unauthorized data access and integrity compromise.

Proof of Concept (PoC):

An unauthenticated remote attacker targets a web store powered by Sylius. The attacker sends a GET request to the payment request API endpoint, replacing the payment ID parameter with another customer's payment ID. The Sylius backend processes the API request, retrieving the sensitive object directly from the database without checking if the current user is authorized to view it. This results in the leakage of payment details and transaction history belonging to other customers.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53639>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53639>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53639>

CVE-2026-54071

Finding: Pickle Deserialization Code Execution in BabelDOC

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 70/100 | CWE: CWE-502

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1204, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Local	Attack Complexity	Low
Privileges Required	None	User Interaction	Required
Scope	Unchanged	Confidentiality Impact	High

Integrity Impact

High

Availability Impact

High

Description:

BabelDOC contains an arbitrary code execution vulnerability within the cmapdb.py module of the pdfminer component. The root cause is the usage of Python's highly insecure pickle library to deserialize CMap database files without prior integrity checks or authentication. An unauthenticated local or remote attacker could exploit this by convincing a user to process a maliciously crafted CMap file, leading to arbitrary code execution.

Proof of Concept (PoC):

An unauthenticated attacker prepares a malicious CMap file containing an embedded Python pickle payload. The attacker uploads or delivers this file to the target application utilizing the BabelDOC pdfminer parser library. The server's babeldoc/pdfminer/cmapdb.py parser invokes the pickle.load() function to process the untrusted file. This results in immediate execution of the embedded Python shellcode, yielding unauthorized command shell access to the attacker.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54071>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54071>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54071>

CVE-2026-54063**Finding: Denial of Service via Unbounded Row Allocation in Excelize**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Unverified

MITRE ATT&CK: T1499, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Excelize contains a denial of service vulnerability in the checkSheet parsing component of its worksheet engine. The root cause is the failure to impose limits on row index size allocations, causing the system to over-allocate memory when parsing malformed files. An unauthenticated remote attacker can exploit this by uploading a crafted Excel spreadsheet, triggering an out-of-memory panic and system crash.

Proof of Concept (PoC):

An unauthenticated remote attacker targets a server that utilizes the Excelize library to process user-uploaded spreadsheet files. The attacker crafts a malicious XLSX file containing an extremely large row index value in one of the worksheet definitions. The backend application parses the file and executes the checkSheet function, which attempts to allocate memory proportional to the excessive row index. This results in an immediate Out-Of-Memory panic, causing the service to crash and denying service to legitimate users.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54063>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54063>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54063>

CVE-2026-54066

Finding: Arbitrary File Read via Path Traversal in SiYuan

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-22

Score Provenance: Unverified

MITRE ATT&CK: T1190, T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	None	Availability Impact	None

Description:

SiYuan contains an arbitrary file read vulnerability via path traversal within the /assets/*path endpoint in publish mode. The root cause is the incomplete resolution of CVE-2026-41894, allowing double URL encoding to bypass file path validation controls. An unauthenticated remote attacker can exploit this to access sensitive files outside the intended root directory, causing severe confidentiality compromise.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies a SiYuan instance operating in public publish mode. The attacker issues a GET request to the /assets/ endpoint, appending double URL-encoded traversal sequences to reach sensitive files. The server decodes the path, bypassing the single-pass path sanitization check, and reads the target file directly from disk. This results in unauthorized disclosure of sensitive files like application configurations and databases from the host filesystem.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54066>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54066>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54066>

CVE-2026-54651

Finding: Denial of Service via Infinite Loop in PyPDF

CVSS v3.1 Score: 5.5 | Severity: Unknown | Urgency Score: 68/100 | CWE: CWE-835

Score Provenance: Unverified

MITRE ATT&CK: T1499, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Local	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

The pypdf library contains a denial of service vulnerability in its writer module when processing threads and articles. The root cause is a failure to validate cyclic references within PDF document threads, leading to an infinite loop during serialization. An unauthenticated remote attacker can exploit this by submitting a malformed PDF document, causing CPU exhaustion and system unresponsiveness.

Proof of Concept (PoC):

An unauthenticated remote attacker targets an application utilizing the pypdf library to merge or rewrite uploaded PDF documents. The attacker crafts a PDF document containing circular references within its thread or article dictionaries and submits it to the application. The server's PDF writer parses the thread entries and falls into an unconstrained while loop while attempting to traverse the cyclic structures. This results in immediate CPU exhaustion, rendering the application container unavailable to handle legitimate requests.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54651>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54651>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54651>

CVE-2026-54070

Finding: Stored XSS in SiYuan Bazaar Marketplace

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 64/100 | CWE: CWE-79

Score Provenance: Unverified

MITRE ATT&CK: T1189, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	High
Availability Impact	Low

Description:

SiYuan suffers from a stored cross-site scripting vulnerability in its Bazaar marketplace module when rendering package README documents. This vulnerability is caused by a failure to sanitize HTML event handlers within markdown README files before they are presented in the marketplace interface. An unauthenticated remote attacker can exploit this by publishing a malicious package, leading to arbitrary JavaScript execution in the context of any user viewing the package details.

Proof of Concept (PoC):

An unauthenticated attacker registers as a package publisher on the SiYuan Bazaar marketplace. The attacker uploads a custom package containing a README.md file embedded with malicious HTML tags and onload event attributes. A victim visits the marketplace and clicks on the attacker's package listing, triggering the client-side rendering of the untrusted README file. This results in the automatic execution of the embedded script in the victim's session, enabling account hijacking or data exfiltration.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54070>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54070>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54070>

CVE-2026-54171

Finding: Sensitive Information Leakage via HTTP Redirects in Excon

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: N/A

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1557, T1020

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

The Excon HTTP client library contains an information disclosure vulnerability when handling HTTP redirects. The root cause is the failure of the client redirect handler to strip sensitive request headers, such as authorization tokens, when routing requests to external, untrusted hosts. A remote attacker controlling a redirect-target server could leverage this to capture sensitive credentials, leading to full confidentiality compromise.

Proof of Concept (PoC):

An unauthenticated remote attacker controls an HTTP server and expects incoming traffic from a victim utilizing the Excon library. The attacker configures their server to issue a 302 redirect pointing to an external destination under the attacker's direct control. The victim's application using Excon issues an initial request containing sensitive authentication headers and automatically follows the redirect without sanitizing the header list. This results in the automatic leakage of the sensitive headers to the attacker's server, enabling unauthorized session hijacking.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54171>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54171>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54171>

CVE-2026-54136

Finding: Authorization Bypass via API Path Traversal in Windmill

CVSS v3.1 Score: 7.5 | Severity: Unknown | Urgency Score: 59/100 | CWE: CWE-863

Score Provenance: Unverified

MITRE ATT&CK: T1056, T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Windmill contains an authorization bypass vulnerability in its scripts/list_search API endpoint. The root cause is a failure in resource-scoped token enforcement logic that permits API calls to query and retrieve script contents outside defined folder constraints. An authenticated attacker with a restricted token can exploit this to read sensitive system scripts and access intellectual property or credentials.

Proof of Concept (PoC):

An authenticated attacker possesses a restricted API token scoped exclusively to a specific resource subdirectory in Windmill. The attacker submits a crafted GET request to the /api/scripts/list_search endpoint using traversal syntax inside the search query parameters. The backend system processes the search request without validating that the targeted search scope strictly matches the token's allowed paths. This results in the exposure and retrieval of full source code from scripts stored outside the authorized boundary.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54136>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54136>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54136>

CVE-2026-54068

Finding: SQLite Data Exfiltration via Template Injection in SiYuan

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-306

Score Provenance: Unverified
MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network	Attack Complexity	High
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	None	Availability Impact	None

Description:

SiYuan is vulnerable to an unauthenticated template injection vulnerability within the /api/icon/getDynamicIcon endpoint. The root cause is the lack of authorization checks and unsafe evaluation of user input during dynamic icon template compilation. An unauthenticated remote attacker can exploit this vulnerability to exfiltrate sensitive data from the SQLite database.

Proof of Concept (PoC):

An unauthenticated remote attacker discovers an exposed SiYuan instance over the network. The attacker sends a POST request to the /api/icon/getDynamicIcon endpoint with a template payload containing structured SQLite queries. The server's template engine executes the embedded query structure without validating user permissions or isolating the template environment. This results in the response body returning the queried secrets from the SQLite database, yielding unauthorized data access.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54068>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54068>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54068>

CVE-2026-48861

Finding: CRLF Injection via Unvalidated Request Headers in Mint

CVSS v3.1 Score: 7.2 | Severity: Unknown | Urgency Score: 48/100 | CWE: CWE-93

Score Provenance: Unverified
MITRE ATT&CK: T1139, T1071

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Changed	Confidentiality Impact	Low
Integrity Impact	Low	Availability Impact	None

Description:

Mint contains a Carriage Return Line Feed (CRLF) injection vulnerability in its HTTP request line parser. The root cause

is a failure to strip carriage return and line feed characters from the method and target variables before creating the request. An unauthenticated remote attacker can exploit this to inject arbitrary headers or split HTTP requests, facilitating cache poisoning or request smuggling.

Proof of Concept (PoC):

An unauthenticated remote attacker targets a server communicating with an external API using the Mint HTTP client. The attacker provides inputs containing raw CRLF characters intended to be processed as the request's method or target parameter. The Mint client constructs the outgoing HTTP stream, embedding the unvalidated characters directly into the request line header section. This results in the target server processing a secondary, smuggled HTTP request or accepting injected HTTP response headers.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-48861>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-48861>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-48861>

CVE-2026-54163

Finding: Content Security Policy Injection in Secure Headers

CVSS v3.1 Score: 4.7 | Severity: Unknown | Urgency Score: 42/100 | CWE: CWE-79

Score Provenance: Unverified
MITRE ATT&CK: T1139, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

The Secure Headers gem suffers from a Content Security Policy (CSP) directive injection vulnerability within its sandbox, plugin_types, and report_to parameter parsing functions. This issue is caused by a failure to properly sanitize user-supplied input before formatting the HTTP response headers containing CSP directives. A remote attacker could exploit this by crafting malicious inputs to inject arbitrary directives, effectively bypassing cross-site scripting (XSS) protections and executing arbitrary scripts.

Proof of Concept (PoC):

An unauthenticated remote attacker targets a web application utilizing the Secure Headers library to enforce security policies. The attacker submits a malicious payload containing newline characters and arbitrary CSP directives via the sandbox parameters of an HTTP request. The application processes the request and appends the unvalidated input directly into the generated Content-Security-Policy HTTP response header. This results in the execution of injected cross-site scripting payloads as the user's browser processes the weakened policy.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54163>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54163>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54163>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent

system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>